

케이뱅크플러스 오픈뱅킹 API 게이트웨이

보안 요구사항서

문서번호	KBP-2027-SEC-114
작성일	2026년 12월 18일
상위 문서	KBP-2027-SOW-114 과업지시서 3.2 · 3.6
적용 범위	게이트웨이 계층과 그 운영 절차. 계정계는 제외한다.
증빙 제출처	발주사 정보보호부

1. 근거 및 적용 원칙

본 문서는 전자금융 부문의 내부 통제 기준과 발주사 정보보호 지침을 본 사업에 맞게 펼친 것이다. 통제 항목은 SEC-01 부터 SEC-14 까지이며, 각 항목은 증빙으로 확인한다. 증빙이 없으면 구현되었더라도 미충족으로 본다.

- 설계 단계에서 통제 항목별 구현 방식을 정하고 발주사 정보보호부의 확인을 받는다.
- 개발·시험 환경은 금융망 안에 두고 운영 데이터를 반입하지 않는다.
- 통제 항목의 예외는 발주사 정보보호부 승인 없이는 두지 않는다.
- 요구사항 정의서 OB-N-07 의 완료 기준은 본 문서 전 항목의 증빙 제출이다.

2. 통제 항목

ID	항목	통제 내용	증빙	대응 과업
SEC-01	전송 구간 암호화	대외 구간은 TLS 1.3 만 허용하고 그 이하 버전은 차단한다.	프로토콜 점검 결과서	G-01
SEC-02	저장 암호화	계좌번호와 고유식별정보는 AES-256-GCM 으로 저장한다.	설정 확인서	G-01
SEC-03	키 관리	암호화 키는 HSM 에 보관하고 키 교체 주기는 180일이다.	키 교체 이력	G-02
SEC-04	기관 인증	기관 인증서는 상호 TLS 에 쓰며 유효기간은 365일이다.	인증서 발급 대 장	G-02
SEC-05	특권 계정	특권 계정은 개인 계정과 분리하고 분기 1회 재승인한다.	재승인 이력	G-02
SEC-06	운영 접근	운영 서버 접근 권한은 승인 후 4시간만 유효하며 만료 시 자동 회수한다.	권한 부여 이력	G-06
SEC-07	로그 위변조 방지	기록은 1시간 단위로 해시 체인을 걸어 봉인한다.	봉인 대장	G-06
SEC-08	거래 기록 보관	전자금융거래 기록은 5년간 보관한다.	보관 정책서	G-06
SEC-09	접근 기록 보관	시스템 접근 기록은 3년간 보관하고 분기마다 점검한다.	점검 결과서	G-06
SEC-10	개인정보 표시	화면과 기록에서 계좌번호는 뒤 4자리만 남기고 가린다.	화면 점검표	G-04
SEC-11	이상 호출 탐지	동일 기관의 호출이 분당 600건을 넘으면 경보한다.	경보 발생 이력	G-03

SEC-12	취약점 점검	정적·동적 점검을 연 2회 수행하고 상위 등급 결함은 남기지 않는다.	점검 결과서	G-06
SEC-13	모의해킹	연 1회 수행하며 대외 개통 전 1회는 반드시 한다.	모의해킹 보고서	G-06
SEC-14	사고 대응	보안 사고 인지 후 2시간 이내에 발주사에 보고한다.	보고 체계도와 훈련 기록	전체

대응 과업별 통제 항목 수

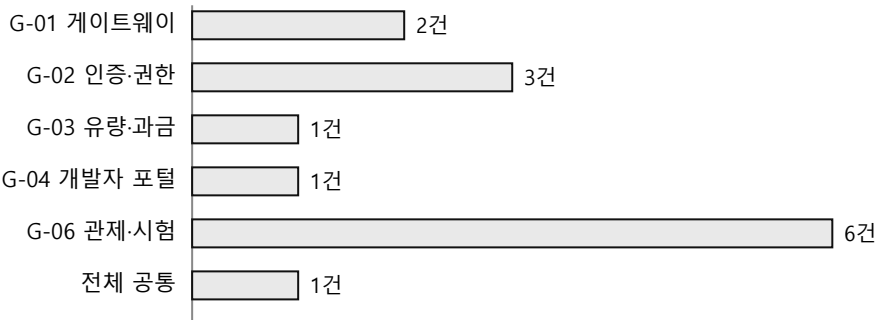


그림 1 대응 과업별 보안 통제 항목 수 (SEC-01 ~ SEC-14)

3. 암호화 상세

전송 구간과 저장 구간을 나눈다. 전송 구간은 대외와 내부를 다시 나누며, 내부 구간이라도 금융망 안이라는 이유로 평문을 허용하지 않는다.

- 대외 구간은 TLS 1.3 만 받는다. 협상 실패는 연결 단계에서 끊고 기록에 남긴다.
- 게이트웨이와 원장 사이 구간도 암호화하며, 사용 알고리즘은 설계 단계에서 확정한다.
- 키는 용도별로 나눈다. 저장용 키와 서명용 키를 같이 쓰지 않는다.
- 키 교체 시 이전 키는 복호화 전용으로 30일 더 두고 그 뒤 폐기한다.
- 키 반출은 금지한다. 백업도 HSM 안에서만 한다.

4. 접근통제

운영 접근은 신청·승인·회수를 한 줄로 남긴다. 상시 권한은 두지 않으며, 필요한 순간에만 받고 자동으로 사라지게 한다.

- 운영 서버 접근은 요청 사유와 대상 서버를 적어 신청하고, 발주사 운영팀장이 승인한다.
- 승인된 권한은 4시간 뒤 자동 회수한다. 연장은 재신청으로만 한다.
- 특권 계정은 사람 이름과 묶어 관리하고 공용 계정을 만들지 않는다.
- 인력 철수 시 당일 안에 계정을 잠그고 5영업일 이내에 삭제한다.
- 포털 관리자 화면은 발주사 사내망에서만 접근할 수 있다.

5. 로깅 및 감사

기록은 남기는 것보다 고쳐지지 않게 하는 것이 중요하다. 봉인 값이 어긋나면 그 구간 전체를 사고로 본다.

- 거래 기록에는 호출 추적 ID, 기관 코드, 스코프, 처리 결과를 담는다.
- 요청 전문에 담긴 개인정보는 기록 전에 가린다.
- 기록은 1시간 단위로 해시 체인을 걸고, 직전 구간의 해시를 다음 구간에 포함한다.

- 봉인 값 검증은 매일 1회 자동으로 돌리고 결과를 정보보호부에 보낸다.
- 감사 목적의 기록 조회는 열람 사유를 남긴다.

6. 점검과 사고 대응

- 취약점 점검에서 나온 상위 등급 결함은 조치 전에 개통하지 않는다.
- 모의해킹은 대외 개통 이전 시험 환경에서 하며, 운영 환경 대상 시험은 발주사 승인 뒤에만 한다.
- 사고 인지 시각은 담당자가 알아챈 시각이 아니라 경보가 뜬 시각으로 본다.
- 사고 보고에는 영향 범위, 차단 조치, 복구 예정 시각을 담는다.
- 사고 종료 후 10영업일 이내에 원인 분석서를 제출한다.

통제 항목의 증빙은 단계별 검수와 별도로 제출한다. 증빙철은 항목 번호 순으로 묶고, 항목마다 확인자와 확인 일자를 적는다.